

Authline — Threat Model

Condensed edition · STRIDE · verified line-by-line against the code on 2026-09-01 · full analysis in [docs/threat-model.md](#)

1 The system in thirty seconds

Authline lets a holder open **and authorize** a trustline on a permissioned (AUTH_REQUIRED) Stellar asset with **one signature**. The issuer hands SAC adminship of the asset to the **Trustline Authorizer** contract, which exposes a permissionless `authorize_trustline` gated by a denylist/allowlist policy, plus an admin console (ban, allow, freeze, pause, mint, clawback, upgrade) gated on the issuer's key. An immutable **onboard router** drives the one-signature flow; an SDK, an HTTP relayer, a dApp and an admin CLI sit around that core. At risk: authorization authority over a regulated asset, the admin key, operators' XLM, and the compliance audit trail.

One enforcement point

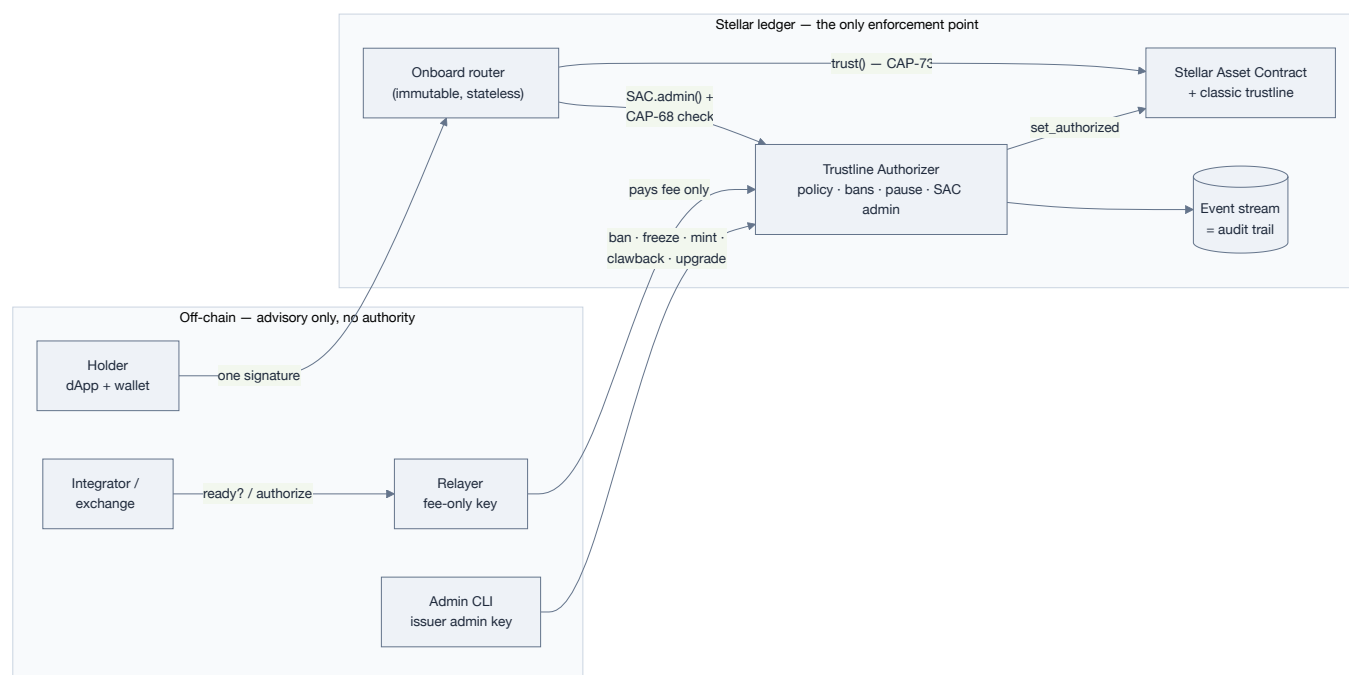
Only the contracts decide. Every off-chain component — relayer, dApp, SDK — is advisory and can mislead but never admit.

No data, no PII

No database anywhere. Contracts speak only addresses, amounts and enumerated codes; KYC data never crosses into the system.

One admin key

A single key holds total authority: policy, unbounded mint, clawback, upgrade, handover. Key custody is the load-bearing control.



2 The five risks that matter most

- 1 The admin key is the whole system** **Critical**

One key sets policy, mints without bound, claws back any balance, upgrades the code and hands over adminship — and `pause()` deliberately cannot contain it, since `set_admin` and `upgrade` stay live while paused. Multi-signature custody with separated compliance/supply roles, plus alerting on privileged events, is mandatory before mainnet. (*Elevation.1/.3*)

- 2 One-step `set_admin` over one-way SAC adminship** High

Handing adminship to a typo or a contract that cannot sign strands the asset permanently — this already forced one testnet re-issuance. A `propose/accept` handshake is the single highest-value contract change in this model. (*DoS.4*)
- 3 A malicious SAC admin under the holder's one signature** High

The router invokes whatever admin the asset names, inside the holder's signed authorization; a hostile admin turns "authorize my trustline" into arbitrary holder-authorized actions. Contained today by the pinned registry; the dApp should also display the simulated auth tree before signing. (*Tamper.1 / Elevation.6*)
- 4 The relayer was an open faucet** RESOLVED 2026-09

It had no rate limiting, an optional API token, and 60 s of blocking per authorize. It now ships per-IP rate limiting and a concurrency cap, refuses non-loopback binds without a 16+-char token (compared constant-time), coalesces concurrent authorizes for one account into a single submission, and refuses to boot if its key is an authorizer admin key. (*DoS.1/.2, E.4, S.7*)
- 5 The audit trail is weaker than it looks** High for compliance

The issuer's own account keeps classic `SetTrustLineFlags`, bypassing the event stream; and RPC event retention is far shorter than statutory retention, with no scheduled export (`history` defaults to a ~1-day window). (*Repudiate.1/.2*)

3 STRIDE at a glance

ID	THREAT	SEVERITY	STATUS
Spoofing			
S.1	Copycat issuer — resolving an asset by code alone hits an attacker's issuer	High	IN PLACE registry pins issuer + SAC; uncurated codes return <code>null</code>
S.2	Hijacked <code>stellar.toml</code> advertises attacker contracts	High	PARTIAL reconciliation rejects mismatches but is opt-in; absent fields skipped
S.3	Substituted onboard router executes under the holder's signature	High	IN PLACE pinned per network; router immutable (mainnet pin pending)
S.4	Forged or substituted wallet-ceremony result; returned XDR never checked against the request	Med	TO DO origin + source checked; add nonce + verify payload
S.5	Rogue relay feeds integrators fabricated answers	Med	IN PLACE relay is advisory; the ledger is the only truth
S.6	Arbitrary contract posing as an asset	Med	IN PLACE CAP-68 executable check in router and authorizer
S.7	Relayer token guessing	Low	IN PLACE constant-time compare, min length, rate-limited
Tampering			
T.1	Malicious SAC admin abuses the holder's folded auth tree — sharpest residual risk in the design	High	PARTIAL contained by pinning; auth-tree display to do
T.2	Reserve drain via blind sponsorship	High	PARTIAL <code>assertSafeToSponsor</code> is strict — but no sponsor service exists to call it
T.3	Hostile contract upgrade — no timelock, no multisig	High	TO DO multisig admin account; publish wasm hashes

T.4	Supply-chain tampering: npm SDK, mutable GHCR : latest , dApp bundle	Med	PARTIAL commit tags exist; pin digests, add provenance + bundle hash
T.5	PUBLIC_* build override silently replaces the registry pin	Med	TO DO console warning today; must fail production builds
T.6	Hand-rolled regex TOML scanner misreads edge cases; fetch follows redirects	Low	PARTIAL bounded + strkey-validated; use a real parser
Repudiation			
R.1	Issuer's classic SetTrustLineFlags path bypasses the event stream	High	PARTIAL documented + cold-custody discipline; monitoring to do
R.2	Audit trail evaporates with RPC retention; no scheduled export	High	TO DO cron history --json into retained storage
R.3	One shared admin key — no per-operator attribution	Med	TO DO multisig + retain signed envelopes
R.4	Relayer keeps no request records	Med	ACCEPTED deliberate privacy; integrators record txHash
R.5	Reason codes are unverifiable claims by the operator	Low	ACCEPTED issuer internal-controls question
Information disclosure			
I.1	Ban/freeze/deauthorize events permanently mark an address in public	High	ACCEPTED inherent to a public-ledger regulated asset; closed vocabulary adds nothing linkable
I.2	Proxy/platform logs pair client IP with Stellar address (GDPR)	Med	TO DO ship a log-scrubbing reverse-proxy config
I.3	Default public RPC provider sees address + IP + timing	Med	PARTIAL endpoints configurable; document the default
I.4	A mis-prefixed PUBLIC_ secret compiles into the public bundle (five .env.* files are tracked)	High	PARTIAL warnings + clean today; add secret-scanning hook/CI

I.5	Full XDR in wallet URL query strings (browser history, wallet-origin logs)	Low	TO DO move payloads to postMessage
I.6	/healthz names the fee account	Low	ACCEPTED discoverable on-ledger anyway
I.7	500 handler returned internal error text verbatim	Low	IN PLACE generic detail since 2026-09
Denial of service			
D.1	Unauthenticated reads amplify into RPC-quota and budget spend	Low	IN PLACE per-IP rate limits + concurrency cap (2026-09)
D.2	Fee drain via POST /authorize: 60 s blocking, check-then-act race	Low	IN PLACE token required off-loopback; capped; authorizes coalesce (2026-09)
D.3	pause() halts onboarding and all non-recovery admin ops from one key	Med	IN PLACE by design, recoverable; consider allowing deauthorize while paused
D.4	One-step set_admin can strand SAC adminship forever — already happened once	High	TO DO propose/accept two-step + scripted pre-flight
D.5	Archived ban entry must fail closed, not read as absent	Med	TO DO regression test + restore procedure
D.6	Single RPC endpoint; cold start after idle	Low	TO DO failover list for production
D.7	Denial by policy: allowlist gaps deny legitimate holders	Low	ACCEPTED regulated admission; refusals made legible
D.8	Authorizer archives itself: permissionless calls never bump the instance TTL (~90 idle days)	Med	TO DO bump TTL in authorize_trustline or run a keeper
Elevation of privilege			
E.1	One admin key: policy, unbounded mint, clawback, upgrade, handover — compromise is total	Critical	TO DO multisig + role split; not optional for mainnet
E.2	Admin secret is read into a Node process with the whole dev dependency tree	High	TO DO sign via stellar tx sign / hardware

E.3	<code>set_admin/upgrade</code> stay live while paused — pause cannot contain a stolen key	High	ACCEPTED deliberate (recoverability); key custody is the only control
E.4	<code>RELAYER_SECRET</code> set to the admin key turns a public endpoint into an admin console	Low	IN PLACE boot check refuses an admin key (2026-09)
E.5	Any third party can choose <i>when</i> a holder is authorized	Low	ACCEPTED grants nothing the policy refuses
E.6	Hostile discovered admin acts with the holder's authority (chain-level face of T.1)	High	PARTIAL router post-condition + pinning; show auth tree
E.7	CLI <code>---id</code> bypasses the registry pin; destructive commands never confirm	Med	TO DO confirmation prompt + pin check
E.8	Freeze does not survive an allowlist → denylist policy switch	Low	TO DO write a ban on freeze regardless of policy

4 Before mainnet — in order of value

- Two-step `set_admin`** (`propose_admin` / `accept_admin`) — D.4/E.1; plus a scripted pre-flight verifying `SAC.admin() == authorizer` before the issuer relinquishes adminship.
- Multisig admin with separated compliance/supply roles**, and out-of-band alerting on `minted`, `clawback`, `admin_changed`, `upgraded`, `policy_set` — E.1/E.3/T.3/R.3. No contract change needed: `require_auth` honours whatever the admin address requires.
- Harden the relayer — done (2026-09-01)**: per-IP rate limits, required API token off-loopback, concurrency cap on the 60 s confirmation wait, coalesced authorizes, and a boot check that the relayer key is not the authorizer admin — D.1/D.2/E.4/S.7. Remaining runbook duty: fee-balance alerting.
- Make registry reconciliation the default** in `discoverOnboarder`, and turn pin-override console warnings into production build failures — S.2/T.5.
- Retain the audit trail**: scheduled `history --json` export into retention-controlled storage, and monitor the issuer account for classic `SetTrustLineFlags` — R.1/R.2.
- Show the holder what they sign**: simulate `onboard` and display the auth tree, refusing anything beyond the expected router → SAC → authorizer shape — T.1/E.6.
- Liveness safety nets**: bump instance TTL from `authorize_trustline` (or a keeper), and a regression test that archived ban entries fail closed — D.8/D.5.
- Move admin signing out of Node** (hand unsigned XDR to `stellar tx sign` or a hardware signer) and add a secret-scanning pre-commit hook + CI check — E.2/I.4.
- Wallet-ceremony integrity**: nonce through the ceremony, verify the returned XDR matches the submitted transaction, validate the redirect `returnUrl` — S.4.
- Supply-chain pinning**: deploy by image digest (never `:latest`), publish provenance/SBOM and the dApp bundle hash — T.4.

5 Risks accepted, with eyes open

- **Public marking of addresses (I.1).** Inherent to every public-ledger regulated asset. The design's obligation — add nothing that eases linkage — is discharged by the closed, enumerated vocabulary: no free-text field exists anywhere in the contract interface.
- **Recovery beats containment (E.3).** A paused contract stays recoverable precisely because `set_admin` and `upgrade` stay live; the flip side is that pause cannot contain a stolen admin key, which is why multisig custody is treated as required, not advisory.
- **The relayer's silence (R.4).** No request logs is a privacy feature; every `authorize` is a signed, permanent ledger transaction, and integrators who need their own trail record the returned `txHash`.
- **Residual risk for uncured assets (T.1).** Outside the pinned registry there is nothing to pin against; the risk transfers to the holder's wallet and is documented in the SEP.

Authline STRIDE threat model, condensed edition · 2026-09-01 · Every claim cross-checked against the repository at the time of writing; 5 corrections applied and 4 threats (D.8, I.7, E.7, E.8) added during verification. Full analysis, mitigations and evidence: `docs/threat-model.md` · Structure follows the Stellar STRIDE template.